INFORMATION SECURITY

BTEUP Polytechnic CSE — 5th Semester

Developer:- Vipin Gangwar

Most Important Question Bank • 35 Detailed Theory Answers • Five Units

Study scope: Covers all five theory units in the supplied syllabus. Practical exercises are not included.

Exam guidance: Use these structured notes to understand and revise concepts. Adapt the length to the question and marks, and verify current legal requirements from official sources.

UNIT 1: INTRODUCTION TO INFORMATION SECURITY

Q1. Define Information Security. Explain the core principles of Information Security (CIA Triad — Confidentiality, Integrity, Availability).

Information Security (InfoSec) is the practice of protecting information and the systems that store, process and transmit it from unauthorised access, alteration, disclosure, destruction or disruption. It applies to digital records as well as printed documents and conversations. The main objective is to preserve trust, privacy and reliable operation.

The CIA Triad contains three core principles:

1. **Confidentiality:** Information should be visible only to authorised people or systems. Access controls, encryption, strong passwords and data classification help maintain confidentiality. For example, a hospital should allow only authorised staff to view a patient's medical record.
2. **Integrity:** Information must remain accurate, complete and protected against unauthorised modification. Hashes, digital signatures, permissions, validation and change records can help detect or prevent tampering. For example, a bank balance must not be altered by an unauthorised user.
3. **Availability:** Information and services should be accessible to authorised users when needed. Backups, redundant systems, patching, disaster recovery and denial-of-service protection support availability. For example, an online examination portal should remain available during registration.

```
Diagram:
                  INFORMATION SECURITY
                     /     |     \
          Confidentiality Integrity Availability
               (secret)   (correct)   (accessible)
```

These principles can sometimes conflict. Strong access restrictions may improve confidentiality but make legitimate access harder. Security design therefore balances risk, usability, cost and legal obligations. Additional goals often include authenticity (confirming identity or origin), accountability (linking actions to users) and non-repudiation (providing evidence that an action occurred).

A practical security programme identifies assets, assesses threats and vulnerabilities, applies proportionate controls, monitors results and improves them over time. No single product guarantees security; people, policies, processes and technology must work together.

Q2. Explain the various aspects of information security (PAIN — Privacy, Authenticity, Integrity, Non-repudiation).

The PAIN model highlights four important aspects of information security: Privacy, Authenticity, Integrity and Non-repudiation. These complement the CIA Triad and help establish confidence in digital transactions.

1. **Privacy:** Personal information should be collected, used, stored and shared only for legitimate purposes and according to applicable rules and user expectations. Data minimisation, access restrictions, retention limits and secure deletion reduce privacy risks. Example: a college should not disclose student phone numbers to unrelated advertisers without an appropriate lawful basis.
2. **Authenticity:** Authenticity means being able to verify that a user, device, message or document is genuinely what it claims to be. Passwords, multifactor authentication, certificates and digital signatures can support authenticity. Example: a website certificate helps a browser verify the identity associated with a secure website connection.
3. **Integrity:** Integrity protects information against unauthorised or accidental changes. Hash values can reveal changes, while access controls and signed records can help prevent or identify tampering. Example: a software download can be checked against a trusted hash value.
4. **Non-repudiation:** Non-repudiation provides evidence that a particular action or message came from a specific party, making it difficult for that party to credibly deny the action later. Digital signatures, reliable timestamps and audit trails may contribute. Their evidential strength depends on private-key protection, identity verification and trustworthy procedures.

Example of an online purchase: authentication verifies the customer, privacy protects their personal details, integrity protects order and payment data, and a signed transaction record may provide evidence of approval.

These aspects are related but not interchangeable. Encryption may protect confidentiality but does not by itself prove that the sender is genuine or that the message has not been altered. A hash can detect a change but cannot identify who created the data unless combined with a trusted mechanism. Effective security selects controls for each requirement and reviews them as threats and laws evolve.

Q3. Explain the Security Features of Operating Systems (Authentication and Access Control).

An operating system (OS) manages users, processes, files, memory and devices. Its security features help ensure that only legitimate users and authorised processes can access resources.

Authentication verifies a claimed identity. Common methods include:
- Something the user knows: password or PIN.
- Something the user has: security key, authenticator or registered device.
- Something the user is: a biometric such as a fingerprint, where supported.
Multifactor authentication combines independent factors and is stronger than relying on a password alone. Secure systems store password verifiers using salted, slow password-hashing methods rather than storing readable passwords. Login rate limits, account lockout policies and alerts can reduce guessing attacks, although lockout must be designed to avoid denial-of-service abuse.

Access control determines what an authenticated identity may do. The principle of least privilege gives each user or process only the permissions necessary for its task. Common models include discretionary access control (owners assign permissions), role-based access control (permissions follow job roles), and mandatory access control (central labels and rules govern access). Permissions may distinguish reading, writing, executing, deleting and changing ownership.

```
Flow:
User claims identity → Authentication check → Session created → Access-control check → Allow or deny resource requ
```

Operating systems also use account separation, privilege elevation, secure boot features, process isolation, updates and security policies. Administrators should use separate standard and administrative accounts where practical. Applications should not run with unnecessary administrator rights because malware can inherit those privileges.

For example, a student account may read course files but not change system settings or inspect another student's private files. Logs can record failed logins and privilege changes. Authentication answers “Who are you?” while authorisation/access control answers “What are you allowed to do?” Both are essential, and neither replaces patching, backups or user awareness.

Q4. Explain File System Protection and User Privileges in OS security.

File-system protection controls access to files, folders and storage devices so that information is not read, changed or deleted by unauthorised users. It is implemented through ownership, permissions, access-control lists, encryption and system policies.

Typical permissions include:
- Read: view or copy file contents.
- Write: modify contents.
- Execute: run a program or script.
- List/traverse: view folder contents or access items through a directory.
- Delete or change permissions: remove objects or alter who can access them.

Many operating systems associate files with an owner and groups. Permissions can be assigned to the owner, group and other users. Access-control lists (ACLs) allow more detailed permissions for specific users or groups. Role-based groups simplify administration because permissions can be changed at group level rather than individually.

User privileges describe the actions a user or process may perform. A normal user should not be able to install system-wide software, change security settings or read protected system files unless authorised. The principle of least privilege reduces the damage caused by mistakes or malware. Temporary privilege elevation is safer than using an administrator account for all routine work.

Other protections include full-disk or file-level encryption, secure file sharing, quotas, file integrity monitoring, backups and secure deletion. Encryption protects data at rest if a device is lost, but it does not prevent access by a user who has already unlocked the system and has valid permissions.

Example: in a college system, teachers may update marks, students may view only their own results, and system administrators may manage accounts. A misconfigured shared folder could expose confidential records, so permissions should be reviewed and tested.

Good practice includes applying least privilege, using groups consistently, protecting administrator credentials, patching the OS, auditing sensitive folders and testing recovery from backups. File permissions are an important control, but they must be combined with authentication, endpoint protection and monitoring.

Q5. What are Audit Features and Logs? How do they help in OS security?

An audit log is a chronological record of security-relevant events produced by an operating system, application or device. Auditing helps administrators detect suspicious activity, investigate incidents, demonstrate compliance and understand changes to systems.

Logs may record:
- Successful and failed login attempts.
- Account creation, deletion and password or permission changes.
- Access to sensitive files and administrative actions.
- Service starts/stops, system errors and security alerts.
- Software installation, policy changes and process activity.

Audit features allow an administrator to select which events are recorded, define retention periods, search and filter records, generate reports and forward events to a central monitoring system. Time synchronisation is important so events from different systems can be compared accurately.

```
Incident workflow:
Event occurs → Log generated → Central collection/correlation → Alert or investigation → Containment and recovery
```

For example, repeated failed logins followed by a successful login from an unusual location may indicate password guessing or account compromise. File-access records may help determine whether sensitive information was viewed or modified.

Logs are useful only if they are reliable and protected. Attackers may attempt to delete or alter them, so sensitive logs should have restricted access, secure transport, backups and, where suitable, tamper-resistant or write-once storage. Administrators should avoid recording unnecessary passwords, authentication secrets or personal data. Excessive logging can create storage and privacy problems; logging should focus on risk and legal requirements.

Audit records do not automatically prevent an attack. They provide evidence and visibility, while access controls, patching and response procedures reduce risk. Organisations should define who reviews alerts, how quickly incidents are escalated and how long records are retained. Regular testing ensures that the right events are being captured and that staff can use the logs during an investigation.

Q6. Explain the concept of RAID options in data security (RAID 0, 1, 5).

RAID stands for Redundant Array of Independent Disks. It combines multiple drives to improve performance, capacity or fault tolerance. RAID can improve availability, but it is not a substitute for a separate backup because accidental deletion, malware, theft or site damage can affect an entire array.

RAID 0 — Striping: Data blocks are distributed across two or more drives. This can improve throughput and uses the combined capacity, but it provides no redundancy. If one drive fails, the array may be lost. It is suitable only where performance is important and the data can be recreated.

RAID 1 — Mirroring: The same data is written to two or more drives. If one mirror drive fails, data may remain available on another. Usable capacity is commonly equal to one drive in a two-drive mirror. Write performance and exact recovery behaviour depend on the controller and system.

RAID 5 — Striping with distributed parity: Data and parity information are distributed across at least three drives. The parity information can reconstruct data after one drive fails. Usable capacity is approximately (number of drives – 1) × capacity of the smallest drive. Rebuilds can be slow and stressful, and a second failure during rebuild can cause data loss.

```
Comparison:
RAID 0: performance/capacity, no fault tolerance.
RAID 1: mirroring, can tolerate a drive failure in a two-drive mirror.
RAID 5: parity, can tolerate one drive failure.
```

RAID controllers and software monitor drive health and may alert administrators when a drive fails. A replacement drive can be rebuilt, but rebuilding should be monitored. RAID levels do not protect against every failure, and actual tolerance depends on the array design.

For an organisation, choose RAID according to workload, budget, recovery objectives and availability requirements. Keep independent, tested backups, including offline or immutable copies where appropriate, and periodically test restoration.

Q7. Discuss the role of Anti-Virus Software and how it detects malware.

Antivirus or endpoint-protection software helps detect, block and remove malicious software such as viruses, worms, trojans, spyware and ransomware. Modern endpoint security may combine several techniques because no single detection method identifies every threat.

Main detection methods:
1. **Signature-based detection:** compares files or code patterns with known malware signatures. It is fast for known threats but may miss new or modified malware until signatures are updated.
2. **Heuristic analysis:** examines suspicious code structures or characteristics that resemble malware.
3. **Behaviour monitoring:** watches actions such as unauthorised encryption of many files, credential theft attempts or unexpected persistence changes.
4. **Reputation and cloud analysis:** uses trusted intelligence to assess files, URLs or processes.
5. **Sandboxing:** runs suspicious content in an isolated environment to observe its behaviour, where supported.

Workflow:
File/download/process → Scan and reputation checks → Allow, quarantine or block → Alert/log → Update or investigate.

Antivirus can scan files on access, run scheduled scans, inspect email attachments and downloads, and receive updates that add detection rules. Quarantine isolates suspicious files so they cannot run normally. Administrators can centrally manage policies and review alerts.

For example, a malicious attachment may be blocked because its signature is known, or its behaviour may be flagged when it attempts to execute an unexpected script. However, attackers may use encryption, obfuscation or previously unknown techniques, and legitimate software can sometimes trigger false positives.

Effective protection also requires timely OS and application updates, least privilege, email filtering, secure backups, multifactor authentication and user awareness. Antivirus does not guarantee safety and should not be used as a reason to open unknown files. Keep protection enabled, verify alerts through trusted procedures and ensure important data can be restored after an incident.

UNIT 2: NETWORKING SECURITY WEAKNESSES

Q8. Explain security weaknesses in the IP and TCP protocols.

IP and TCP are core Internet protocols, but their original designs prioritised interoperability and delivery rather than comprehensive security. Security therefore depends on network controls and secure protocols layered above them.

IP weaknesses: IP provides addressing and routing but does not inherently authenticate the claimed source address or encrypt packet contents. Source-address spoofing can make a packet appear to come from another host. Attackers may exploit fragmentation, malformed packets, route manipulation or traffic floods. IPsec can add authentication and confidentiality, while ingress filtering, firewalls and rate limits reduce certain risks.

TCP weaknesses: TCP establishes connections using a handshake and manages sequencing, retransmission and flow control. Predictable or guessed connection information, weak implementations and resource exhaustion can be exploited. SYN floods abuse half-open connection state; spoofing can complicate filtering; and unencrypted TCP application data may be observed or modified by an attacker positioned on the path. TCP itself does not provide application-level identity or encryption.

Simplified TCP connection:
Client → SYN → Server
Client ← SYN-ACK ← Server
Client → ACK → Server

Mitigations include stateful firewalls, SYN cookies or equivalent protections, rate limiting, secure configuration, patching, anti-spoofing filters and monitoring. Use TLS for web and other supported application traffic, or IPsec for network-layer protection. Strong authentication should be applied at the application layer.

A common misconception is that TCP's checksum is a security mechanism. It helps detect accidental corruption, but it is not a cryptographic integrity check and does not prove who sent a packet. Similarly, knowing an IP address is not proof of identity.

Security should be designed in layers: filter traffic at network boundaries, restrict unnecessary ports, segment internal systems, encrypt sensitive communications and monitor anomalies. These measures reduce risk but must be adapted to the network architecture and threat model.

Q9. Explain security weaknesses in UDP, RIP, and OSPF protocols.

UDP, RIP and OSPF serve different networking purposes and have different security concerns.

UDP (User Datagram Protocol): UDP is connectionless and does not establish a session like TCP. It offers low overhead but does not guarantee delivery, ordering or retransmission. Its checksum can detect some accidental corruption, not authenticate the sender. Spoofed UDP packets can support reflection/amplification attacks against exposed services, and floods can consume bandwidth or processing resources. Mitigations include filtering unnecessary UDP services, rate limiting, source validation and secure application protocols.

RIP (Routing Information Protocol): RIP uses hop count to choose routes and has historically had limited authentication in some deployments. Untrusted routing updates can influence route selection or create incorrect routing information. Use supported authentication, restrict routing updates to trusted interfaces, filter routes and disable RIP where it is unnecessary.

OSPF (Open Shortest Path First): OSPF exchanges link-state information among routers in an area. If unauthorised devices can form adjacencies or inject false routing information, they may disrupt route calculation or redirect traffic. Authentication support, interface restrictions, router-ID planning, route filtering where applicable, and monitoring help protect it. Configuration and feature support vary by OSPF version and vendor.

```
Diagram:
Router A ← trusted routing updates → Router B
                  |
          authentication + interface controls
```

Network teams should keep routing protocols off user-facing interfaces, permit only expected peers, protect management access and monitor route changes. Network segmentation limits the impact of a compromised segment. Routing authentication protects protocol messages but does not replace physical security, patching or sound network design.

For an exam answer, distinguish transport-layer UDP from routing protocols RIP and OSPF. UDP carries application data; RIP and OSPF allow routers to exchange route information. Their mitigations differ, so a single generic firewall rule is not sufficient.

Q10. Explain security vulnerabilities in HTTP and SMTP.

HTTP and SMTP are application-layer protocols widely used for web access and email. Their basic forms do not by themselves provide the full confidentiality and authentication required for modern communication.

HTTP: Ordinary HTTP sends requests and responses without encryption. A person able to observe the network may read data or alter traffic. Websites may also be vulnerable to application flaws such as injection, cross-site scripting, broken access control, insecure sessions and request forgery. These are not all defects in HTTP itself; they often arise from unsafe

application design. Use HTTPS with correctly configured TLS, secure cookies, input validation, output encoding, access checks, security headers and timely patching.

SMTP: SMTP transfers email between clients and mail servers or between mail servers. Without suitable protection, traffic may be observed or modified in transit. Email sender fields can be forged, and misconfigured open relays can be abused to distribute spam. Attachments and links may carry malware or phishing content. SMTP encryption through STARTTLS or implicit TLS protects a connection when correctly negotiated, but it does not automatically provide end-to-end encryption or prove that the visible sender address is genuine.

Mitigations for email include authenticated submission, strong account security, anti-spam and malware filtering, SPF, DKIM and DMARC domain protections, user education and careful attachment handling. These controls reduce spoofing but do not eliminate all phishing.

Web flow:
Browser → HTTPS/TLS connection → Web server → Application checks → Response.

Email flow:
Sender → Authenticated submission → Mail transfer servers → Recipient server → Filtering → Mailbox.

Use HTTPS for websites and secure mail configurations. Security must also include application testing, patch management, logging and incident response; encryption alone cannot fix a vulnerable web application or a deceptive email.

Q11. Discuss security weaknesses in common networking devices (Hub, Switch, Router).

Hubs, switches and routers connect devices, but they operate differently and expose different risks.

Hub: A traditional hub repeats incoming signals to all ports. Devices on the same hub segment may receive traffic not intended for them, making passive observation easier. Hubs also provide little traffic isolation and can spread the impact of local traffic floods. They are largely obsolete in modern switched networks.

Switch: A switch forwards Ethernet frames based on MAC addresses. Misconfiguration, insecure management, spoofed MAC addresses, VLAN hopping attempts, spanning-tree manipulation and broadcast storms may threaten availability or segmentation. An attacker may try to fill a switch's MAC table so that some traffic is flooded, although protections and behaviour vary by device. Mitigations include port security, unused-port shutdown, VLAN design, 802.1X access control, storm control, secure spanning-tree settings and management-plane protection.

Router: A router connects IP networks and makes forwarding decisions. Weak administration passwords, exposed management interfaces, outdated firmware, insecure routing configuration, spoofed traffic and incorrect access-control lists can expose networks. A router may also be targeted by denial-of-service traffic. Mitigations include secure management protocols, multifactor authentication where available, firmware updates, least-privilege administration, ingress/egress filtering, routing authentication and configuration backups.

```
Comparison: a hub repeats signals; a switch forwards frames within a LAN; a router forwards packets between IP networ
```

Example: a college network can place student devices, staff systems, servers and guest Wi-Fi in separate VLANs, then use router or firewall rules to restrict movement between them. Secure configuration and monitoring matter as much as device type. Replace unsupported hardware and regularly review configurations.

Q12. What are the security risks associated with Wi-Fi networks?

Wi-Fi provides convenient wireless access but broadcasts radio signals beyond the immediate room. An attacker within range may attempt to observe traffic, impersonate a network or exploit weak configuration.

Major risks include:
- **Weak encryption or passwords:** obsolete protocols and simple shared passwords can permit unauthorised access.
- **Rogue access points:** an unauthorised device may create an unapproved wireless entry into the internal network.
- **Evil-twin attacks:** a fake access point copies a legitimate network name to trick users into connecting.
- **Eavesdropping and man-in-the-middle attacks:** unsafe networks or certificate warnings may expose traffic or credentials.
- **Unauthorised clients:** shared passwords can be passed to people who should not have access.
- **Misconfiguration:** default administrator credentials, outdated firmware, WPS weaknesses or poorly separated guest networks increase risk.
- **Denial of service:** interference or deliberate disruption can make wireless service unavailable.

Security measures include WPA3 where supported, or a properly configured WPA2-AES deployment when required; long unique passphrases; enterprise authentication such as 802.1X for organisations; firmware updates; disabling unnecessary WPS; changing default admin credentials; and monitoring connected devices. Guest networks should be isolated from sensitive internal resources. VPNs can add protection on untrusted networks, but do not make a phishing site safe.

Users should verify the network name, avoid ignoring certificate warnings and use HTTPS. Organisations should survey coverage, protect access-point management and maintain an inventory of authorised devices.

```
Diagram:
```

```
Wireless client → Access point (strong encryption/authentication) → Firewall/VLAN controls → Approved services.
```

Encryption protects radio traffic, but it cannot prevent all threats from a compromised device or malicious website. Wi-Fi security therefore requires secure endpoints, network segmentation, identity controls and user awareness.

Q13. Explain IPSec and how it secures network communication.

IPsec (Internet Protocol Security) is a suite of protocols that protects IP traffic at the network layer. Depending on configuration, it can provide data confidentiality, integrity, data-origin authentication and protection against replay.

The main components include:
- **AH (Authentication Header):** provides integrity and origin authentication for supported packet fields, but not encryption; it is less commonly used in many modern deployments.
- **ESP (Encapsulating Security Payload):** can provide encryption, integrity and authentication. It is widely used.
- **Security Associations (SAs):** define security parameters such as algorithms, keys, lifetimes and traffic selectors.
- **IKE/IKEv2:** negotiates keys and security associations and authenticates peers.

IPsec commonly operates in two modes. **Transport mode** protects the IP payload while retaining the original IP header, often for host-to-host protection. **Tunnel mode** encapsulates an entire original IP packet inside a new IP packet, commonly used in site-to-site or remote-access VPNs.

```
Flow:
Host A → IPsec encryption/authentication → Untrusted network → Verification/decryption → Host B.
```

IPsec can protect traffic between branch offices, remote users and data centres even when packets cross public networks. It is generally transparent to applications because protection is provided below the transport layer.

Security depends on strong algorithms, secure key management, correct peer authentication, careful traffic selectors and regular updates. Weak shared secrets, overly broad access rules or incorrect routing can undermine a deployment. IPsec does not protect data after it reaches a compromised endpoint, and it does not automatically fix insecure applications. Use least privilege, logging, patching and monitoring alongside IPsec. A well-configured IPsec VPN helps establish a protected channel across an untrusted network.

Q14. Explain VLAN and VPN. How do they mitigate security risks?

A VLAN (Virtual Local Area Network) logically divides a switched network into separate broadcast domains. A VPN (Virtual Private Network) creates a protected logical connection across a network that may be untrusted. They solve different problems and are often used together.

VLAN: Switch ports or network interfaces are assigned to separate logical networks. For example, staff, students, servers and guests can be placed in different VLANs. This limits ordinary Layer 2 traffic and helps contain broadcast traffic. Communication between VLANs normally requires Layer 3 routing, where access-control rules can be applied. VLANs alone are not encryption and do not guarantee security if trunking, routing or switch configuration is incorrect.

VPN: A VPN uses tunnelling and commonly encryption plus authentication to protect data across networks. Remote-access VPNs connect individual users; site-to-site VPNs connect offices. IPsec and TLS-based technologies are common approaches. A VPN helps protect traffic in transit, particularly on public networks, but a compromised endpoint can still expose data.

```
Diagram:
Staff VLAN ■■
Server VLAN ■■■ Controlled router/firewall ■ Approved services
Guest VLAN ■■■
Remote user ■■ encrypted VPN tunnel ■■ organisation gateway
```

VLAN mitigations: segmentation, reduced unnecessary visibility, policy separation and containment. VPN mitigations: confidentiality and integrity in transit, peer authentication and secure remote connectivity.

Use both thoughtfully: put VPN users into an appropriate restricted VLAN or access group, apply least-privilege rules, monitor access and require strong authentication. Avoid treating a VLAN as a substitute for a firewall or a VPN as a substitute for endpoint security. Regularly review routes, permissions and network diagrams.

Q15. What is Ingress Filtering? How does it protect a network?

```
Ingress filtering checks incoming packets at a network boundary and rejects traffic that should not arrive from that
```

For example, if a provider knows that a customer network uses a particular set of public IP addresses, it can filter packets arriving from that customer if they claim an impossible or unauthorised source address. This reduces the ability of compromised hosts to send spoofed traffic that may support denial-of-service attacks or conceal origins.

```
Basic logic:
Packet arrives → Inspect source/destination and policy → Valid/expected? → Forward
                                                    ■ No → Drop and optionally log

Ingress filtering can be implemented through router access-control lists, firewall rules, unicast reverse-path checks
```

It is useful to distinguish ingress filtering from egress filtering. Ingress filtering checks traffic entering a network; egress filtering checks traffic leaving it. Egress controls can stop internal devices from sending packets with forged external source addresses and can restrict outbound traffic to approved destinations or services.

```
Ingress filtering is not a complete defence against denial-of-service attacks, because attackers may use valid source
```

UNIT 3: CRYPTOGRAPHY AND PUBLIC KEY INFRASTRUCTURE

Q16. What is Cryptography? Explain the difference between Symmetric and Asymmetric encryption.

Cryptography is the science of protecting information using mathematical techniques. It supports confidentiality, integrity, authentication and digital signatures. Encryption converts readable plaintext into ciphertext using an algorithm and key; decryption converts it back for an authorised recipient.

Symmetric encryption uses the same secret key, or closely related shared key material, to encrypt and decrypt. It is generally fast and suitable for large amounts of data. Examples include AES and ChaCha20. Its main challenge is securely sharing and protecting the key: anyone who obtains it may decrypt protected data.

Asymmetric cryptography uses a mathematically related public/private key pair. The public key can be distributed, while the private key must remain secret. Depending on the algorithm, public-key techniques support encryption/key establishment or digital signatures. Examples include RSA and elliptic-curve cryptography. Asymmetric operations are often slower than symmetric encryption, so systems commonly use them to authenticate peers or establish shared session keys.

Hybrid encryption flow:
Sender → Use recipient public-key method to establish/protect a session key
→ Encrypt bulk data with symmetric cipher → Send
Recipient → Use private key to recover/establish session key → Decrypt data

Symmetric encryption is efficient for bulk data; asymmetric methods help solve key establishment and identity problems. Secure systems often combine them, as TLS does. A digital signature is not simply encryption with a private key; it is a separate cryptographic operation with defined verification rules.

Security depends on modern algorithms, correct modes, random nonces/keys, safe implementation and key management. Do not invent your own cipher. Cryptography cannot compensate for compromised endpoints, exposed keys or poor access control.

Q17. Explain the concept of Hashing and Message Digest in security.

A cryptographic hash function takes input data of any practical length and produces a fixed-length output called a hash value or message digest. A secure hash is designed to be computationally difficult to reverse and to make it difficult to find two different inputs with the same output.

Important properties:
1. **Deterministic:** the same input produces the same digest.
2. **Fixed output length:** for a given algorithm, digest size is fixed.
3. **Preimage resistance:** given a digest, finding an input that produces it should be infeasible.
4. **Second-preimage resistance:** given one input, finding another with the same digest should be infeasible.
5. **Collision resistance:** finding any two distinct inputs with the same digest should be infeasible.
6. **Avalanche effect:** a small input change should produce a substantially different digest.

Example:
File → SHA-256 hash → digest
Received file → SHA-256 hash → compare digests

If the digests differ, the files differ. A hash alone does not prove who created a file, because an attacker could replace both the file and its published digest. Authenticity can be strengthened by signing the digest digitally or obtaining it from a trusted channel.

Hashes are used for file-integrity checks, digital signatures, data structures and password verification. Passwords should not be stored as plain hashes of fast general-purpose algorithms. Use a salted password-hashing scheme such as Argon2id, scrypt, bcrypt or PBKDF2, configured appropriately, because password guessing is a special threat.

Hashing is not encryption: it is normally one-way and has no decryption key. It is also not the same as a message authentication code (MAC), which uses a secret key to authenticate a message. Select current, approved algorithms and avoid obsolete choices such as MD5 or SHA-1 for security-sensitive collision-resistance needs.

Q18. What is Public Key Infrastructure (PKI)? Explain its core components.

Public Key Infrastructure (PKI) is a framework of people, policies, processes, hardware and software used to create, distribute, validate and revoke digital certificates that bind identities to public keys. PKI supports secure websites, signed software, encrypted email, device identity and enterprise authentication.

Core components include:
1. **Certificate Authority (CA):** signs certificates after following defined identity-validation procedures. A root CA is highly trusted; intermediate CAs can issue certificates under it.

2. **Registration Authority (RA):** verifies identity information or performs enrolment checks on behalf of a CA, where used.
3. **Digital certificate:** commonly an X.509 certificate containing a subject identity, public key, issuer, validity period, serial number and CA signature.
4. **Public/private key pair:** the public key is shared; the private key must be protected by its owner.
5. **Certificate repository:** makes certificates and related information available.
6. **Revocation mechanisms:** Certificate Revocation Lists (CRLs) or Online Certificate Status Protocol (OCSP) may communicate certificate status.
7. **Policies and procedures:** define identity proofing, key protection, issuance, renewal, revocation and incident handling.

Certificate validation flow:
Server certificate → Check CA signature and trust chain → Check name and validity → Check status/purpose → Establish trusted connection.

A browser uses trusted root certificates to validate a website certificate. If the certificate is invalid, expired or issued for a different name, the browser may warn the user.

PKI trust is only as strong as its CA procedures and private-key protection. If a CA or private key is compromised, fraudulent certificates may be issued or trusted identities impersonated. Organisations must renew certificates on time, restrict CA access, protect keys, monitor expiry and revoke compromised certificates. A certificate binds a key to an identity; it does not mean the website's content is automatically safe.

Q19. Explain Digital Signatures and how they ensure Non-Repudiation.

A digital signature is a cryptographic mechanism that allows a recipient to verify that signed data is associated with a particular private key and has not been altered since signing. When the key is reliably linked to a person's identity and well protected, signatures can contribute to authenticity, integrity and non-repudiation.

```
Signing process:
1. The sender prepares the message or document.
2. A cryptographic hash function computes a digest.
3. The signing algorithm uses the sender's private key and the digest to create a signature.
4. The sender transmits the message, signature and, when needed, a certificate.

Verification:
Message + signature → Hash message → Verify signature using public key
                        Compare/validate → Accept or reject
```

If the message changes, verification normally fails. The private key should remain under the control of its authorised owner; the public key can be distributed in a certificate.

Non-repudiation means providing evidence that makes it difficult for a signer to deny having signed a particular message. The strength of that evidence depends on reliable identity verification, secure private-key custody, trustworthy timestamps, audit records, policy and applicable law. A stolen private key or shared credentials can weaken the conclusion that a specific person signed.

A digital signature is not the same as encrypting a document. It may leave the content readable while proving integrity and key association. Confidentiality requires encryption separately if needed.

Uses include signed contracts, software releases, tax filings and electronic documents. Before relying on a signature, verify the certificate chain, validity, revocation status, signature algorithm and signed content. Digital signatures provide strong technical evidence, but legal effect depends on the applicable jurisdiction and circumstances.

Q20. What are the security considerations while developing software applications (Secure Coding)?

Secure coding means designing, implementing and testing software to reduce vulnerabilities throughout the development lifecycle. Security should be included from requirements through maintenance, not added only after release.

Key practices:
1. **Validate input:** check type, length, range and format on the server side. Prefer allow-lists for structured input.
2. **Prevent injection:** use parameterised database queries and safe APIs rather than concatenating untrusted data into SQL, shell commands or templates.
3. **Authentication and sessions:** use established libraries, multifactor authentication where appropriate, secure password hashing, session expiry and secure cookie settings.
4. **Authorisation:** check permissions on every protected operation; never rely only on hiding a button in the user interface.
5. **Output encoding:** encode data according to its output context to reduce cross-site scripting.
6. **Secrets management:** never hard-code API keys or passwords in source control. Use managed secrets and rotate exposed credentials.
7. **Cryptography:** use approved libraries, modern protocols and safe defaults; do not design custom cryptographic algorithms.
8. **Error handling and logging:** provide useful internal logs without exposing stack traces, passwords, tokens or personal data

to users.
9. **Dependency and configuration security:** update libraries, remove default accounts, disable unused services and protect build pipelines.
10. **Testing and review:** use code review, threat modelling, static/dynamic analysis, dependency scanning and authorised penetration testing.

Secure development flow:
Requirements → Threat model → Secure design → Coding/review → Testing → Release → Monitoring/patching.

For example, an online marks portal must verify that a student can view only authorised records and that a request cannot modify another student's marks. This requires server-side access checks, not just a hidden edit button.

Security is continuous. Monitor vulnerabilities after release, respond to reports, maintain supported dependencies and provide a process for security updates. Follow recognised guidance such as OWASP resources and the organisation's own secure-development standard.

Q21. Explain the role of SSL/TLS in securing web applications.

SSL and TLS are cryptographic protocols used to protect communication between clients and servers. SSL is obsolete and insecure; modern web applications should use correctly configured TLS. HTTPS is HTTP carried over TLS.

TLS can provide:
- **Confidentiality:** encryption helps prevent observers from reading data in transit.
- **Integrity:** message authentication detects unauthorised modification.
- **Server authentication:** certificates help a browser verify that it is communicating with the intended website.
- **Optional client authentication:** certificates can identify clients in specialised systems.

Simplified handshake:
Browser → Supported versions, algorithms and key-share information
Server → Certificate and handshake information
Browser → Validates certificate and server name
Both → Derive session keys and confirm handshake
Then → Encrypted HTTP data

Modern TLS commonly uses ephemeral key exchange to establish session keys, then efficient symmetric cryptography protects application traffic. Certificate validation is essential: users and applications must check the hostname, trust chain and validity rather than blindly accepting warnings.

TLS does not protect data before it is encrypted or after it is decrypted at an endpoint. It also does not automatically stop phishing, SQL injection, weak passwords or malicious code. A website can use HTTPS and still be unsafe.

Good practice includes using current TLS versions, disabling obsolete protocols and weak cipher suites, renewing certificates, protecting private keys, redirecting HTTP to HTTPS, enabling secure cookies and testing configuration. HSTS can help browsers use HTTPS consistently. Mixed content and insecure redirects should be eliminated.

For example, TLS protects login credentials while they travel from a browser to a website. The application must still store passwords securely and enforce authorisation. TLS is therefore a foundational transport security control, not a complete application-security solution.

UNIT 4: NETWORK SECURITY PRODUCTS

Q22. What is a Firewall? Explain the different types of Firewalls (Packet Filtering, Stateful, Proxy).

A firewall is a hardware or software security control that monitors and permits or blocks network traffic according to a defined policy. It creates a boundary between networks or systems with different trust levels.

Packet-filtering firewall: examines packet headers such as source/destination IP addresses, protocol and ports. Rules may permit HTTPS while blocking unnecessary inbound services. It is relatively fast but may not understand connection context or application content.

Stateful firewall: tracks connection state and determines whether packets belong to an allowed established session. It can reject unsolicited packets that do not match expected state. Stateful inspection offers more context than simple stateless filtering, but it still may not understand every application-level threat.

Proxy/application firewall: acts as an intermediary between client and server. It can inspect application requests and responses, enforce content or protocol rules and hide internal systems. A proxy may introduce latency and needs careful configuration. A web application firewall (WAF) is a specialised control for HTTP application traffic.

Example:
Internet → Perimeter firewall → DMZ web server → Internal firewall → Protected database.

Firewalls can be network-based, host-based or cloud-managed. They support least privilege by allowing only required traffic. Rules should be specific, documented, reviewed and logged. Default-deny policies are often safer than allowing everything and attempting to block a few known threats.

A firewall cannot replace endpoint security, secure coding, identity controls or monitoring. Misconfigured rules, exposed management interfaces and overly broad exceptions can weaken protection. Administrators should patch firewall software, back up configurations, test changes and review logs. The correct firewall type depends on traffic volume, application needs, risk and operational capacity.

Q23. Explain the working and importance of IDS (Intrusion Detection System).

An Intrusion Detection System (IDS) monitors network traffic or host activity for signs of malicious behaviour, policy violations or suspicious events. Its main role is detection and alerting; a traditional IDS generally does not automatically block the traffic it observes.

Types:
- **Network IDS (NIDS):** monitors traffic at a network observation point.
- **Host IDS (HIDS):** monitors events on an individual system, such as logs, file changes and process behaviour.

Detection approaches include signature-based detection, which matches known patterns, and anomaly-based detection, which identifies deviations from a baseline. Some systems combine both. Signatures can detect known attacks efficiently but may miss new variants; anomaly detection can identify unusual activity but may generate false positives.

Workflow:
Traffic/events → Sensor and analysis engine → Rule or anomaly match → Alert/log → Analyst triage → Response.

For example, an IDS may alert when a host scans many ports, when repeated login attempts occur or when traffic matches a known exploit pattern. Security staff investigate the source, affected assets, timing and supporting logs before deciding on containment.

IDS is valuable because it improves visibility, supports incident response and can reveal activity that bypasses preventive controls. Sensors should be placed at useful network points and tuned to the organisation's normal traffic. Time synchronisation, secure log storage, updates and clear alert ownership improve usefulness.

Limitations include encrypted traffic visibility, missed events, false positives, false negatives and sensor overload. An IDS does not guarantee that an attack will be detected or stopped. It should be combined with firewalls, endpoint protection, vulnerability management and tested incident-response procedures. Analysts must validate alerts rather than treating every alert as proof of compromise.

Q24. Explain the working and importance of IPS (Intrusion Prevention System).

An Intrusion Prevention System (IPS) inspects network traffic or system activity and can take automatic action when it identifies traffic matching its security policy. Unlike a passive IDS, an inline network IPS can block packets, reset connections or temporarily restrict a source.

Common detection methods include signatures for known attacks, protocol analysis and behavioural/anomaly detection. A network IPS is commonly positioned inline so traffic passes through it; a host-based prevention system can restrict processes or system actions.

Workflow:
Incoming traffic → IPS inspection → Policy/signature analysis
■■ Legitimate → Forward
■■ Malicious/suspicious → Drop, reset, quarantine or alert

For example, an IPS may block a packet pattern associated with a known exploit or stop repeated attempts to exploit a vulnerable service. It can reduce the time between detection and containment, especially for well-understood threats.

Important considerations include:
- **False positives:** legitimate traffic may be blocked, interrupting business.
- **False negatives:** attacks may evade detection, especially if signatures or policies are incomplete.
- **Performance:** deep inspection can add latency or reduce throughput.
- **Encrypted traffic:** inspection may be limited unless traffic is decrypted through an approved, secure design.
- **Updates and tuning:** signatures and rules must reflect current threats and local applications.

Deploy IPS policies carefully, begin with monitoring or conservative blocking where appropriate, test changes and maintain a documented exception process. Use high availability and fail-open/fail-closed decisions based on risk. Logs should record blocked events and support investigation.

IPS is a preventive layer, not a complete security solution. It works best alongside segmentation, patching, secure configuration, endpoint protection, application security and incident response. The organisation should regularly verify that sensors are active, rules are current and blocked events are reviewed.

Q25. What is a VPN Concentrator? How does it handle secure connections?

A VPN concentrator is a specialised network device or software service that terminates and manages many Virtual Private Network connections. It is commonly used by organisations to provide secure remote access or connect branch offices to a central network.

Typical functions include:
1. **Tunnel establishment:** negotiates VPN parameters using a supported protocol such as IPsec or a TLS-based VPN.
2. **Authentication:** verifies users or devices through certificates, credentials, multifactor authentication or an identity provider.
3. **Encryption and integrity:** protects data in transit and checks that packets have not been modified.
4. **Address and route assignment:** assigns virtual addresses and determines which internal networks the user may reach.
5. **Policy enforcement:** applies access restrictions, session limits and sometimes posture checks.
6. **Session management:** tracks connected users, timeouts, bandwidth and tunnel status.
7. **Monitoring:** records authentication results, connection events and errors.

```
Connection flow:
Remote device → Internet → VPN concentrator
                  [authenticate + establish encrypted tunnel]
               → Access policy/VLAN/firewall → Approved internal resources
```

A concentrator can support many simultaneous tunnels and centralise policy management. It may integrate with directory services, multifactor authentication, endpoint compliance checks and central logging.

Security depends on strong authentication, current software, protected management interfaces, modern cryptographic settings and least-privilege access. A successful VPN login should not automatically grant access to every internal system. Segmentation and per-application access policies reduce the impact of compromised credentials.

Capacity planning is important because encryption, concurrent sessions and traffic inspection consume resources. Redundancy and tested failover support availability. A VPN protects the tunnel, but it does not guarantee that the remote device is free from malware or that every accessed application is secure.

Q26. Explain the concept of Content Screening Gateways.

A content screening gateway is a security control that inspects web, email, file or other application content as it passes between users and external services. It enforces organisational policies and helps block malware, phishing, unsafe downloads, data leakage or access to prohibited content.

Examples include secure web gateways, email security gateways and data-loss-prevention gateways. Depending on the product, features may include URL categorisation, reputation checks, antivirus scanning, attachment sandboxing, file-type controls, spam filtering, data-pattern detection and policy-based blocking.

Workflow:
User request or message → Gateway inspection → Policy/reputation/content checks
■■ Allowed → Deliver
■■ Suspicious/blocked → Quarantine, deny or alert

For example, an email gateway may quarantine a message containing a malicious attachment. A web gateway may block a known phishing URL or prevent a managed device from downloading an unapproved file type. A data-loss-prevention feature may detect an attempt to upload sensitive records to an unauthorised service.

Gateways provide centralised enforcement and visibility, but their effectiveness depends on current threat intelligence, sensible policies and correct integration. Encrypted traffic creates a challenge: inspecting it may require TLS interception, which has privacy, legal, certificate-management and performance implications. Organisations should use transparent, approved policies and avoid unnecessary collection of personal information.

False positives can interrupt legitimate work, while new or obfuscated threats may evade detection. Provide a controlled exception process, user warnings, logging and review. Content screening should complement endpoint protection, access control, secure email authentication, employee training and incident response. It is not a reason to trust every item that passes the gateway.

Q27. Discuss the difference between IDS and IPS.

IDS and IPS both identify suspicious activity, but their position and response differ.

IDS (Intrusion Detection System):
- Usually observes a copy of network traffic or host events.
- Detects patterns and generates alerts or logs.
- Normally does not directly block the traffic.
- Allows analysts to investigate before taking action.
- May be deployed out-of-band, reducing the risk that the sensor itself interrupts traffic.

IPS (Intrusion Prevention System):
- Commonly inspects traffic inline or monitors host activity with prevention controls.
- Can automatically drop packets, reset sessions, quarantine activity or apply a blocking rule.
- May stop certain attacks immediately.
- Can introduce latency and may block legitimate traffic if misconfigured.
- Requires careful high-availability and failure-mode planning.

```
Diagram:
IDS: Traffic ■■■■■■■■■■■■■■■■→ Destination
              ■→ IDS sensor → Alert
IPS: Traffic → IPS inspection → Allowed traffic → Destination
                        ■→ Malicious traffic blocked
```

Both may use signatures, protocol analysis and anomaly detection. Both require tuning, updates, secure logging and response procedures. An IDS can provide broad visibility; an IPS can enforce immediate preventive action. Some modern platforms combine both functions.

Example: an IDS alerts on repeated attempts to exploit a server, while an IPS configured with a matching rule may block the malicious packets. The IPS may still miss a novel or encrypted attack, and an IDS alert may be missed if nobody reviews it.

Choose according to risk, performance, tolerance for disruption and operational capability. A common design uses IPS for well-understood threats at important boundaries and IDS monitoring at additional points for visibility. Neither replaces patching, firewalls, secure application development or endpoint controls.

Q28. How do enterprise networks combine Firewalls, IDS, and IPS for maximum security?

Enterprise security uses multiple complementary controls because no single device can prevent every attack. Firewalls enforce traffic policy, IDS provides detection and visibility, and IPS can automatically block known or policy-defined malicious traffic.

A common design:
Internet → Edge router/anti-spoofing → Perimeter firewall/IPS → DMZ
↓
Internal segmentation firewall
↓
User VLANs / application / database
IDS sensors monitor selected network links
Logs → SIEM or central monitoring → Response team

Firewall role: allow only necessary connections, segment trust zones, restrict administrative access and log important events. Public-facing services are commonly placed in a demilitarised zone (DMZ) rather than directly on an internal network.

IPS role: inspect traffic inline and block known exploit patterns, suspicious protocol use or prohibited connections. Rules must be tuned to avoid disrupting legitimate services.

IDS role: observe traffic and host events at strategic locations, alert on suspicious behaviour and provide evidence for investigation. Out-of-band sensors can monitor traffic without becoming a direct forwarding dependency.

Central monitoring can correlate firewall denies, IDS alerts, IPS blocks, endpoint alerts and authentication events. An incident-response process then validates the event, isolates affected systems, preserves evidence, restores services and updates controls.

Maximum security does not mean blocking everything indiscriminately. It means applying least privilege, segmenting networks, maintaining accurate asset inventories, patching systems, protecting management interfaces, using multifactor authentication and regularly testing backups and response plans. Encrypted traffic, false positives and blind spots must be considered.

Organisations should document rule ownership, review exceptions, test high availability and measure alert quality. Defence in depth works when controls are coordinated and maintained—not merely when several products are installed.

UNIT 5: STANDARDS, LAWS AND SECURITY AUDITS

Q29. Explain the ISO 27001 standard for Information Security Management.

ISO/IEC 27001 is an international standard specifying requirements for an Information Security Management System (ISMS). An ISMS is a systematic way to manage information-security risks through policies, responsibilities, risk assessment, controls, monitoring and continual improvement. Certification, where obtained, applies to a defined scope and does not mean that every possible attack is impossible.

Core ideas include:
1. **Context and scope:** understand the organisation, interested parties, legal obligations and systems covered.
2. **Leadership:** management establishes policy, responsibilities and support for the ISMS.
3. **Risk assessment:** identify information assets, threats, vulnerabilities, likelihood and potential impact.
4. **Risk treatment:** select controls to reduce, avoid, transfer or accept risk, with accountable approval.
5. **Statement of Applicability:** document selected controls, their applicability and justified exclusions.
6. **Operation and awareness:** implement processes, train staff and manage changes.
7. **Performance evaluation:** monitor measures, perform internal audits and review the ISMS with management.
8. **Improvement:** correct nonconformities and continually improve the system.

Cycle:
Plan → Do → Check → Act → repeat.

Controls may address access management, cryptography, supplier relationships, incident handling, business continuity, physical security and asset management. The specific control set depends on risk and the applicable edition of the standard.

For example, a college handling student records may identify risks from stolen credentials, lost laptops and ransomware, then apply multifactor authentication, encryption, backups, staff training and incident-response procedures.

ISO 27001 is not merely a technical checklist. It requires a managed, evidence-based process. Organisations should consult the current standard and qualified guidance for implementation and certification. Legal compliance, secure engineering and practical risk reduction remain necessary even if an organisation is certified.

Q30. Discuss the key provisions of the Indian IT Act related to security.

The Information Technology Act, 2000, as amended, is a major Indian law governing electronic records, electronic signatures and certain cyber offences. It supports electronic transactions and provides legal provisions relevant to unauthorised access, data protection duties and cybercrime. This is an educational overview, not legal advice; current statutory text and case law should be checked for a real matter.

Important provisions commonly discussed in information-security courses include:
- **Section 43:** provides for compensation-related liability for specified unauthorised acts involving computer systems, such as unauthorised access or damage, subject to the statutory conditions.
- **Section 43A:** historically addressed compensation for failure by a body corporate to protect sensitive personal data or information through reasonable security practices. Its present interaction with later data-protection legislation and amendments should be checked against current law.
- **Section 65:** addresses tampering with computer source documents in specified circumstances.
- **Section 66:** covers certain acts described in Section 43 when done dishonestly or fraudulently.
- **Sections 66C and 66D:** concern identity theft and cheating by personation using computer resources.
- **Section 66E:** addresses violation of privacy in specified circumstances.
- **Sections 67 and related provisions:** address certain prohibited electronic material, subject to statutory wording.
- **Section 70:** concerns protected systems and restricted access to specified critical systems.
- **Section 70B:** establishes the national incident-response role of CERT-In under the Act.
- **Section 72:** addresses breach of confidentiality and privacy in specified circumstances.

Organisations should maintain access controls, logs, incident-response processes, employee awareness and appropriate reporting procedures. They should also consider applicable rules and other laws, including India's data-protection framework, because obligations may arise from more than one statute.

The legal position can change through amendments, rules and judicial interpretation. For examinations, learn the section numbers and their broad subject accurately, but do not assume a short summary replaces the statutory text. For a live incident, consult current official government sources and qualified legal counsel.

Q31. What are IPR (Intellectual Property Rights) Laws? Why are they important in IT?

Intellectual Property Rights (IPR) are legal rights protecting certain creations of the mind, including software, literary works, inventions, designs, brands and confidential business information. In IT, IPR helps clarify who may use, copy, modify, distribute or commercially exploit digital products.

Major forms include:
1. **Copyright:** protects original expression such as software code, documentation, graphics, music, videos and website content, subject to the applicable law. It does not generally protect an abstract idea by itself.
2. **Patents:** may protect qualifying inventions that meet legal requirements. Patentability of software-related inventions depends on jurisdiction and statutory exclusions.
3. **Trademarks:** protect brand identifiers such as names and logos, helping distinguish goods or services.
4. **Trade secrets/confidential information:** protect valuable confidential know-how when reasonable secrecy measures are maintained.
5. **Design rights:** may protect qualifying visual designs under applicable law.

Importance in IT:
- Encourages investment in software and digital content.
- Helps creators and organisations license work and earn revenue.
- Reduces unauthorised copying, distribution and brand misuse.
- Supports clear agreements with employees, contractors and vendors.
- Helps organisations manage open-source licence obligations and third-party assets.

Example: a company using an open-source library must follow its licence terms. Copying a paid application's code or using a protected logo without permission may create legal risk. Buying a software licence does not necessarily transfer copyright ownership.

Good practice includes maintaining an asset inventory, reviewing licences, obtaining permissions, preserving licence notices, defining ownership in contracts, protecting confidential materials and using a process for handling infringement claims. IPR rules vary by country and type of work. Organisations should not assume that content found online is free to reuse. For a dispute or licensing decision, consult current law and qualified legal advice.

Q32. Explain the procedure of performing a basic Security Audit.

A security audit is a structured assessment of whether an organisation's systems, controls and procedures meet defined security requirements. It identifies weaknesses, checks evidence and recommends corrective actions. The scope and permission must be agreed before testing begins.

Typical procedure:
1. **Define scope and objectives:** identify systems, networks, sites, business processes, standards and exclusions. Obtain written authorisation.
2. **Plan and identify assets:** prepare an inventory, stakeholders, schedule, risk limits and communication plan.
3. **Review policies and documents:** examine access policies, asset records, change management, backups, incident procedures and previous findings.
4. **Assess risks and controls:** identify threats, vulnerabilities, likelihood and impact; review whether controls are appropriate.
5. **Collect evidence:** inspect configurations, patch status, user permissions, logs, firewall rules, backup reports and training records. Use approved vulnerability scanning or testing within scope.
6. **Validate findings:** confirm issues, estimate severity and avoid unnecessary disruption. Record evidence securely.
7. **Report:** describe each finding, affected asset, risk, evidence, impact and practical recommendation.
8. **Remediate and retest:** assign owners and deadlines, implement fixes and verify that they work.
9. **Follow up:** track unresolved risks and report to management.

Audit flow:
Plan → Collect evidence → Evaluate controls → Record findings → Report → Remediate → Retest.

For example, an audit may discover that former employees still have active accounts or that backups have never been restored in a test. Recommendations should identify actions such as disabling accounts and conducting a recovery exercise.

An audit is not only a vulnerability scan. It also reviews people, policies, processes and evidence. Keep records confidential, follow legal and organisational requirements, distinguish confirmed facts from assumptions and prioritise findings by risk. A successful audit improves security when its recommendations are implemented and checked.

Q33. What are the key elements of developing a Security Policy for an organization?

A security policy is an approved statement of rules, responsibilities and expectations for protecting an organisation's information and technology. It provides consistent direction for employees, contractors and service providers.

Key elements include:
1. **Purpose and scope:** explain why the policy exists and which people, devices, data, locations and services it covers.
2. **Roles and responsibilities:** identify management, IT/security teams, data owners, users, suppliers and incident coordinators.
3. **Asset and data classification:** define categories such as public, internal, confidential and highly sensitive, with handling requirements.
4. **Access control:** require unique accounts, least privilege, appropriate authentication, periodic access reviews and prompt removal of unnecessary access.

5. **Acceptable use:** explain permitted use of email, internet, devices, software and organisational accounts.
6. **Data protection:** address encryption, secure transfer, retention, backup, disposal and privacy.
7. **Endpoint and network security:** define patching, malware protection, remote access, Wi-Fi, segmentation and secure configuration.
8. **Incident reporting:** state how to report suspected phishing, lost devices, data exposure and system compromise.
9. **Third-party security:** set expectations for suppliers and cloud services.
10. **Compliance and enforcement:** identify relevant laws, consequences of violations, exceptions and approval routes.
11. **Review and training:** assign an owner, review schedule, approval authority and awareness programme.

Development flow:
Identify risks and obligations → Draft policy → Consult stakeholders → Approve → Communicate/train → Monitor compliance → Review/update.

A policy should be understandable and enforceable. Overly broad rules that staff cannot follow may encourage workarounds. Supporting standards and procedures should explain technical details such as password configuration or backup schedules. For example, the policy can require sensitive data to be encrypted, while a technical standard specifies approved algorithms and key-management practices.

Policies must evolve as the organisation, threats and laws change. Measure compliance, document exceptions and ensure leadership supports the policy through resources and example.

Q34. Explain Disaster Recovery (DR) and its importance.

Disaster Recovery (DR) is the set of plans, technologies and procedures used to restore IT systems, applications and data after an event such as ransomware, hardware failure, fire, flood or a major service outage. Its objective is to restore agreed services within acceptable time and data-loss limits.

Important concepts:
- **Recovery Time Objective (RTO):** the target maximum time to restore a service after disruption.
- **Recovery Point Objective (RPO):** the maximum acceptable amount of data loss measured in time.
- **Backup:** a separate copy of data that can be restored.
- **Replication:** copies changes to another system or site; it may also replicate corruption or malicious encryption if not protected.
- **Recovery site:** an alternate location or cloud environment used when the primary site is unavailable.

DR lifecycle:
Prepare → Detect incident → Declare recovery → Restore infrastructure/data → Validate service → Resume operations → Review.

A robust plan identifies critical systems, dependencies, owners, recovery order, communication channels, access credentials and restoration procedures. Backups should be protected from ordinary administrator compromise, stored separately or immutably where appropriate, and tested regularly. A backup that cannot be restored is not a reliable recovery capability.

Example: if a college database server fails, the IT team may restore the database from a protected backup to replacement infrastructure and validate student records before reopening the portal. The recovery time depends on backup age, data volume, hardware and testing.

DR reduces downtime, data loss, financial impact and reputational harm. It should include cyber incidents, not only physical disasters. Plans must be updated when systems change and tested through tabletop exercises or realistic recovery drills. DR focuses primarily on restoring technology; broader business continuity planning covers the people and processes needed to continue essential operations.

Q35. What is Business Continuity Planning (BCP)? How does it differ from Disaster Recovery?

Business Continuity Planning (BCP) is the process of preparing an organisation to continue its most important business activities during and after a disruption. A disruption may involve technology failure, cyberattack, supplier loss, staff shortage, building damage or a public emergency.

A BCP typically includes:
1. **Business impact analysis (BIA):** identify critical activities, dependencies, maximum tolerable disruption and consequences of downtime.
2. **Risk assessment:** consider likely threats and vulnerabilities.
3. **Continuity strategies:** determine alternate work locations, manual procedures, backup suppliers, remote working and communications.
4. **Roles and communications:** assign decision-makers, contact lists, staff responsibilities and stakeholder messages.
5. **Recovery priorities:** define which activities resume first and what resources they need.
6. **Training and exercises:** test plans, record gaps and update procedures.

Disaster Recovery (DR) is a related but narrower area focused mainly on restoring IT infrastructure, applications and data. **BCP** covers the wider business operation, including people, facilities, processes, suppliers and customers. DR is often one component of a BCP.

```
Comparison:
BCP: keep essential business services operating.
DR: restore technology and data that support those services.
```

Example: during a college system outage, the BCP may provide temporary student communication, alternate exam arrangements and manual attendance records. The DR plan restores the student database, network and portal. Both plans must coordinate so restored technology supports the actual business priority.

Useful measures include RTO and RPO for technology recovery, plus business-specific targets for essential activities. Plans should be approved by management, accessible during an outage, and tested under realistic conditions. Dependencies such as cloud providers, telecom services and key staff must be considered.

BCP is not just a document stored on a server that may itself be unavailable. Keep controlled copies accessible, assign owners and update the plan after exercises, incidents and organisational changes.

LAST-MINUTE REVISION

Revise each keyword as a definition, working principle, one example and one mitigation/control.

Information Security: Protecting information and systems against unauthorised access, alteration, disclosure, destruction and disruption.

CIA Triad: Confidentiality = secret; Integrity = accurate; Availability = accessible.

PAIN: Privacy, Authenticity, Integrity, Non-repudiation.

Authentication / Authorisation: Verify identity / determine permitted actions.

Least privilege: Grant only the access necessary for the task.

Logs and audits: Evidence, monitoring, accountability, investigation and compliance.

RAID 0 / 1 / 5: Striping without redundancy / mirroring / striping with distributed parity.

Antivirus: Signatures, heuristics, behaviour monitoring, reputation and sandboxing.

IP / TCP / UDP: Addressing and routing / reliable transport / connectionless transport.

RIP / OSPF: Routing protocols; protect updates and restrict trusted peers.

HTTP / SMTP: Web transfer / email transfer; use TLS and application-level controls.

IPsec: Network-layer protection; AH, ESP, security associations, IKE; transport/tunnel modes.

VLAN / VPN: Logical LAN segmentation / protected tunnel across a network.

Ingress filtering: Reject packets with invalid or unexpected source addresses at network boundaries.

Cryptography: Symmetric encryption is fast with shared keys; asymmetric uses public/private keys.

Hash: Fixed-length digest; not encryption; SHA-256 is a common integrity hash.

PKI: CA, RA, certificates, public/private keys, repositories and revocation.

Digital signature: Integrity and key-associated authenticity; supports non-repudiation with trustworthy processes.

TLS: Encrypts and authenticates supported network connections; HTTPS = HTTP over TLS.

Firewall / IDS / IPS: Filter traffic / detect and alert / detect and block.

VPN concentrator: Terminates many authenticated, encrypted VPN sessions.

Content gateway: Screens web/email/files for malware, policy violations and data leakage.

ISO/IEC 27001: ISMS requirements, risk assessment, controls, audit and continual improvement.

Indian IT Act: Know the broad scope of Sections 43, 65, 66, 66C, 66D, 66E, 70 and 70B; check current law.

IPR: Copyright, patents, trademarks, trade secrets and licences.

Security audit: Scope → evidence → assess → report → remediate → retest.

Security policy: Scope, roles, access, data handling, incidents, compliance, training and review.

DR / BCP: DR restores IT; BCP maintains essential business operations.

RTO / RPO: Target time to restore / acceptable time-based data loss.

EXAM PRESENTATION CHECKLIST

• Begin each answer with a precise definition, then explain the working principle in a logical order.

• Draw and label the CIA Triad, TCP handshake, IPsec flow, encryption flow and IDS/IPS diagrams where relevant.

• For comparisons, state the key difference clearly and include a practical example.

• For network-security answers, include both the weakness and the mitigation.

• For legal questions, learn the broad statutory subject and verify current law before relying on it outside an exam.

• Use accurate technical terms, readable headings and concise conclusions.

Help & Support: t.me/axv_god

Pre-caution: These notes are strictly for your best exam preparation. These notes do NOT guarantee passing the exam. Please do not live in this illusion and do not rely solely on this; study thoroughly and aim to gain excellent marks.